Thesis — Research Transition Bridge

CISE 699, Fall 2026

AI-Driven Cybersecurity Risk Management: A Systematic Review of Emerging Threats, Security Controls, and Governance Challenges

Gaurav Sharma

Instructor: Majid Shaalan, Ph.D.

Harrisburg University of Technology

October 18, 2026

Bridge Note

I am further along in my thesis than my earlier checkpoints showed. Those checkpoints were written for build projects, so each time I had to translate my literature review into that language. This note uses the research words that this rubric gives me instead. Because of that, it should give a clearer picture of where my thesis stands than anything I have turned in so far.

My research question has not changed since Hard Stop 1. It asks: what does the published research actually show about tracing AI-related cybersecurity threats all the way to specific controls and named governance rules? And where does that chain break down in the two closest existing reviews, Albulayhi and Alkhalifah (2026) and Mokgathi and Ogundele (2026)? Neither review builds a full threat-to-control-to-governance chain. Closing that gap is still the point of this thesis. The twenty-two sources I have verified so far show that this gap is real, not just something I assumed.

My method is still the same: a PRISMA 2020 systematic review (Page et al., 2021) with narrative synthesis (Popay et al., 2006). I will check it against the NIST AI Risk Management Framework, ISO/IEC 42001, and NIST CSF 2.0, and score it with AMSTAR 2 (Shea et al., 2017) once full screening is done. None of that has changed. What is new is that I now have a small amount of real evidence that the procedure actually works, not just a plan on paper.

In early October, I ran a pilot of my search-and-screening procedure. I used my finalized search string on a live database, then screened the first five results against my inclusion and exclusion rules, with a reason written down for each one. All five were on-topic, so all five were included. This is a small, honest sample, five records out of a target of forty to eighty. It tells me the steps of the procedure work, but it does not prove the full set of sources will behave the same way. Full-scale screening across all seven databases has not started yet. The one part of my design with no evidence behind it at all is the framework-validation step, where I map a chosen control to a specific governance rule. This is the single highest-risk part of the thesis, because my whole claim about tracing threats depends on this step working, and I have not tested it yet.

I am keeping my research question and my plan to validate against all three governance frameworks, exactly as written. I am not narrowing anything because of the pilot. My reason is the evidence from the pilot: the search and screening steps work on real data. If they had failed, that would have forced a change, but nothing in the pilot points to a problem with the question

itself. There is one possible change still on the table, not decided yet, but already built into my method rather than invented just now: validating against at least two of the three governance frameworks instead of all three, if full validation runs short on time. That fallback was part of my method from the start. I am not adding it now to excuse a bad result. I am naming it here so the record shows it was planned ahead of time, not made up after the fact.

The biggest gap right now is the framework-validation mapping. My next step is full-scale screening, because I cannot honestly test the mapping step until I have enough screened and sorted sources to map from. I still need two decisions from my supervisor, and I have not gotten them yet as of this writing. First, should the framework-validation pilot start on a small batch of screened sources at the same time as full screening, instead of waiting for screening to finish? Second, is it acceptable for this thesis if I am the only reviewer, checked by my own spot-check instead of a second coder? Both questions are written down as pending in my risk log, because they have not been decided yet. For Assignment 08, I plan to bring the first real block of full-scale screening results. This will be a meaningful part of the forty-to-eighty target, with every decision logged and explained, plus the results of my screening-consistency spot-check once about ten percent of that is done.

Over Assignments 08 through 14 I will follow the build order already set in my design package: full-scale screening over the next two to three weeks, the framework-validation pilot on five to eight already-screened sources once enough of the corpus is in, full validation against the governance frameworks after the pilot holds up, and the closing AMSTAR 2 and PRISMA checklists with the conclusion in the final two weeks, finishing within the existing December 6 submission date. The real risk in that plan is time: screening forty to eighty sources properly, each with a logged reason, takes longer than it sounds, and it is competing with the same eight to ten hours a week as everything else in the course. If screening runs long, my fallback is the two-of-three governance validation already built into the method, not a shortened source count, since the source range is the benchmark my review's own completeness check is measured against.

1. Inventory of Existing Work

Every item below comes from a dated submission I already turned in for this course. None of it is written for the first time in this note.

Item	Status	Dated To	Authorship
Research question and gap statement	Complete	Assignment 1 (Sept 2026); reaffirmed Hard Stop 1 and Hard Stop 2	Mine; I wrote the gap claim and checked it myself against Albulayhi and Alkhalifah (2026) and Mokgathi and Ogundele (2026)
Critical literature (22 sources, verified)	Complete for the pre-screening set; full-scale screening still ahead	Assignment 1, Hard Stop 1, Hard Stop 2 (20 sources); 2 added for NIST developments	Mine; AI helped find and summarize two sources, but I decided how each one is used and cited

Item	Status	Dated To	Authorship
Review method (PRISMA, narrative synthesis, governance validation)	Complete as a written protocol; only the pilot stage has been run	Hard Stop 2, Section 2.4–2.5	Mine; I chose this method and explained why, after weighing other options
Permission records	Not applicable	Scoped out from the start	Mine; my project charter (Assignment 1) says clearly that I will not collect data from real organizations, so this literature review does not need human-subjects review
Early validation of the search-and-screening procedure	Partial — pilot only (5 of a 40–80 source target)	Early October 2026; evidence kept in a dated project log	Mine; I ran the search and made the screening decisions, with drafting help on how to record them
Screening tracker for full-scale screening	Complete as a tool; not yet populated with full-scale results	Early-to-mid October 2026	Built with AI assistance from the schema I already fixed in Assignment 1 and Assignment 3; I will make every screening decision myself
Risk and issue log	Current; two items open	Maintained since early October 2026	Mine; restructured with AI assistance into the fields this bridge asks for
Supervisor decision on screening arrangement and sequencing	Awaiting review	Requested; not yet received	Not applicable — outcome pending

2. One Completed Item, Explained

The pilot search-and-screening procedure check

What I did: I used the search string I finalized in Assignment 1 and Hard Stop 1 on a live, free database. Then I took the first five results and checked each one against my inclusion and exclusion rule: on-topic for AI cybersecurity risk management, and not primary data collection, not low-level algorithm detail, and not detail that could be used to carry out an attack. I wrote down a decision and a clear reason for each one. I ran the exact same search again, in a completely separate attempt, to make sure the first result was not a fluke that could not be repeated. Both tries gave about the same number of results, roughly 80,700, with the same five records at the top in the same order.

What this shows: the search string really does return a large, relevant set of results that I can repeat, not just a string that looks good on paper. It also shows that my screening rule gives a clear, defensible decision on real records, not only on made-up examples. Both of these have to work before anything else in my method can work. If either one had failed, I would have had to change my review design before starting full-scale screening.

What is still untested: five records do not prove how the rule will behave across the full forty to eighty sources, especially the unclear cases that a pilot this small is unlikely to turn up. It also says nothing about the screening-consistency check itself, since a spot-check needs a bigger sample to mean anything. And it says nothing at all about the framework-validation mapping, which no check has touched yet. I am stating this limit plainly so a passing pilot does not look like more than it really is.

3. Scope and Protocol: Retaining the Question

I am keeping my question, my method, and my goal of validating against all three governance frameworks, exactly as written. I am not narrowing anything because of the pilot. My reason is the evidence from Section 2: the search and screening steps work on real data. If they had failed, that would have forced a change, but nothing in the pilot points to a problem with the question itself. There is one possible change still on the table, not decided yet, but already built into my method rather than invented just now: validating against at least two of the three governance frameworks instead of all three, if full validation runs short on time. That would weaken my claim from “validated against NIST AI RMF, ISO/IEC 42001, and NIST CSF 2.0” to “validated against at least two of the three.” That is a real step down in strength, and it would make my thesis harder to compare to the two existing reviews it is positioned against. I am naming that consequence now, not after the fact.

4. Critical Gap and First Assignment 08 Target

My highest-priority issue is the framework-validation mapping: taking a selected control and mapping it to a governance and compliance rule. This is the one stage, out of eight, in my design with no technical evidence behind it. I cannot test it honestly without a real batch of screened and sorted sources to map from. That is why my next allowed step is full-scale screening, not the mapping step itself.

To settle this, I need my supervisor's decision on two open questions. I have logged both as pending, not guessed at: should the framework-validation pilot start on an early batch at the same time as screening, instead of waiting for the full forty-to-eighty range? And is my single-reviewer screening setup, checked by my own spot-check at about ten percent, an acceptable substitute for a second coder? Neither question has been answered yet, so I am not writing down a decision that has not actually been made.

What I will bring to Assignment 08: a real, logged block of full-scale screening results. Not the full forty-to-eighty range, but a meaningful part of it, with every decision explained and the source database recorded for each one. I will also bring the results of my screening-consistency spot-check once that subset reaches about ten percent of the target.

5. Plan for the Remaining Work (08–14)

Stage	Evidence / Writing Output	Feedback Action
08 (now – next 2–3 weeks)	First logged block of full-scale screening; screening-consistency spot-check at ~10%	Apply my supervisor's decision on sequencing and the screening arrangement once received
09–10	Framework-validation pilot on 5–8 already-screened sources	Review the pilot mapping with my supervisor before scaling up
11–12	Full framework validation against the governance frameworks (three, or two if the fallback in Section 3 is needed)	Confirm with my supervisor which frameworks the final validation covers
13–14	Completed AMSTAR 2 worksheet, PRISMA 2020 checklist, and conclusion, within the existing December 6 date	Final read-through with my supervisor before submission

The main risk to this plan is time, not my method. Screening forty to eighty sources properly, with a reason logged for each one, takes longer in real life than it sounds. It also has to fit inside the same eight to ten hours a week the syllabus sets aside for everything else in this course. My risk log already lists the two items most likely to affect this plan: the single-reviewer screening setup, still open and waiting on my supervisor's sign-off, and the framework-validation mapping itself, still untested. If full-scale screening falls behind schedule, my fallback is the two-of-three governance validation already written into my method. I will not quietly shrink the source count instead, because the forty-to-eighty range is the benchmark my review's own completeness check is measured against.

Progress Notes

- Research question and literature base: no change. 22 sources verified. No new gaps found since Hard Stop 2.
- Procedure check: ran and repeated the search-and-screening pilot on 5 of the 40–80 target sources. All five were on-topic and included, with reasons logged.
- Full-scale screening: not started yet. This is my next step and my main focus before Assignment 08.
- Framework-validation mapping: untested. This is the highest-risk item in my design. I have flagged it to my supervisor and the decision is pending.
- Open questions for my supervisor: (1) when the framework-validation pilot should start compared to full screening, (2) whether the single-reviewer spot-check setup is acceptable. Both are still pending.
- No change to the question, method, or the December 6 final-submission date.

AI-Use Log and Verification

I used Claude to help write this bridge note from the record I already had, to put my risk log into the fields this bridge asks for, and to help find and summarize two NIST sources that I later decided how to cite. I did not use any AI tool to make a screening decision, a scope decision, or the gap claim my thesis is built on. I also did not use any AI tool to produce the pilot search results; that was a live search I ran and checked myself. Every fact in this note, the dates, the source count, the pilot results, the open risk items, comes from a record I can point to, and I checked each one myself before putting it in this note. Where something has not actually been decided yet, like the timing of the framework-validation pilot and the single-reviewer setup, I wrote it down as pending instead of letting a draft make it sound like a decision had already been made.

Links to Existing Evidence

- Research question, gap statement, and charter: Assignment 1 (Launch Packet), submitted and evaluated.
- Method and eight-stage design: Hard Stop 2 (Design Review Package), submitted September 27, 2026.
- Pilot search-and-screening evidence, risk log, and screening tracker: dated project log maintained since early October 2026 (gsharma1989/CISE--699, https://github.com/gsharma1989/CISE--699).
- Verified literature (22 sources) and full citations: Assignment 1, Hard Stop 1, and Hard Stop 2 bibliographies.